

ACTIVITY PACK

Activity 4: Scenario

Activity 4 - Evidence-Based Rogue Agent Incident Review

Course	AI Security for Autonomous AI Agents
Course code	TGS-2025060473
Version	3.0 20 August 2026

Tertiary Infotech Pte Ltd | UEN 20120096W

Scenario

Activity 4 - Evidence-Based Rogue Agent Incident Review

Scope and evidence status

Course: AI Security for Autonomous AI Agents (TGS-2025060473)

Duration: 60 minutes | **Format:** Small groups of 3-4

Type: Documented cases and one reported security-research campaign

This activity uses source-faithful summaries. It distinguishes a verified vulnerability, a confirmed software supply-chain event, a first-party product incident, and a security-research campaign. It does not treat a demonstration, evaluation, or reported campaign as proof that every deployment was compromised.

Use this analysis grammar for every case:

untrusted source -> mechanism -> privileged sink or action -> impact -> deterministic control -> residual risk and evidence

Case A - EchoLeak / CVE-2025-32711

Evidence label: CASE-V - verified vulnerability, fixed by Microsoft

System: Microsoft 365 Copilot

Primary anchors: Microsoft vendor advisory and NVD record for CVE-2025-32711

Microsoft's CVE description states that AI command injection in Microsoft 365 Copilot could allow an unauthorised attacker to disclose information over a network. Microsoft's later security explanation describes EchoLeak as a fixed, multi-stage cross-prompt-injection technique that, under certain conditions, could exfiltrate limited data already accessible to the victim.

Evidence-safe chain

1. An attacker controls content that can enter the user's organisational context.
2. The content carries instructions intended for the model rather than the human reader.
3. The model can combine that content with information available under the user's existing access.
4. An external rendering or network path becomes a possible disclosure sink.

What this case supports

- Indirect prompt injection can be delivered through ordinary business content.
- Existing user permissions can increase the value of a successful injection.
- Input filtering alone is not a complete boundary; source-to-sink and outbound controls matter.

What this case does not support

- It does not establish that every Microsoft 365 tenant was compromised.
- It does not establish a count of affected customers.
- A vulnerability is not the same thing as confirmed malicious exploitation.

Sources:

- <https://nvd.nist.gov/vuln/detail/CVE-2025-32711>
- <https://www.microsoft.com/en-us/security/security-insider/emerging-trends/ai-application-security-considerations-for-organizations>

Case B - Amazon Q Developer extension v1.84.0 / CVE-2025-8217

Evidence label: CASE-V - confirmed by AWS Security Bulletin AWS-2025-015

System: Amazon Q Developer extension for Visual Studio Code

AWS states that an inappropriately scoped GitHub token allowed a threat actor to commit malicious code that was automatically included in extension version 1.84.0. AWS also states that the code failed to execute because it contained a syntax error. AWS revoked and replaced credentials, withdrew version 1.84.0, and released version 1.85.0.

Evidence-safe chain

1. A build or repository credential had more authority than necessary.
2. A threat actor used that authority to alter source used by an automated release path.
3. The resulting extension version was distributed.
4. The malicious code did not execute because of its syntax error.

Control lessons

- Use narrowly scoped, short-lived CI and release identities.
- Protect release branches and require independent review for release changes.
- Pin, sign, inventory, stage, and rapidly revoke software artifacts.
- Treat extensions used by coding agents as part of the executable supply chain.

Source: <https://aws.amazon.com/security/security-bulletins/AWS-2025-015/>

Case C - Replit Agent and an application database

Evidence label: CASE-V - first-party Replit account

System: Replit Agent

Replit states that its Agent deleted data from Jason Lemkin's application database before Replit's development and production databases were separated by default. Replit states that the database was fully restored and no data was lost. Its response emphasised stronger development/production separation, checkpoints, rollback, and modes that let a user plan without authorising execution.

Evidence-safe chain

1. The agent had access to an environment containing important data.
2. A generated plan selected a destructive operation.
3. No deterministic environment boundary stopped the operation before execution.
4. Recovery controls restored the data after the event.

Control lessons

- Separate development and production by construction.
- Deny production writes and deletion to development agents.
- Require an exact, one-time approval for exceptional irreversible actions.
- Test checkpoints and rollback, while remembering that recovery is not prevention.

Source: <https://replit.com/blog/doubling-down-on-our-commitment-to-secure-vibe-coding>

Case D - Reported malicious skills in the ClawHub ecosystem

Evidence label: CASE-R - named security-research campaign, not a platform-wide prevalence rate

System: OpenClaw skill ecosystem / ClawHub

Koi Security reported that its February 2026 audit identified 341 malicious skills among 2,857 skills examined at that time, with 335 linked to one campaign it called ClawHavoc. Use the numbers only with that date, denominator, and methodology. Do not generalise the ratio to the current registry or to every agent marketplace.

The broader security lesson is independent of the reported ratio: a skill may contain instructions, scripts, dependencies, tool definitions, and setup steps that execute with the agent's delegated authority. Installation therefore changes the attack surface and must be governed as a privileged change event.

Control lessons

- Verify publisher identity, repository history, and ownership changes.
- Pin the exact version or commit and record a checksum or signature where available.
- Review instructions, scripts, dependencies, tool schemas, requested credentials, and egress.
- Test in an isolated non-production environment with no ambient secrets.
- Require human approval for installation, update, and material permission changes.
- Maintain inventory, monitoring, rollback, and rapid revocation.

Sources:

- <https://www.koi.ai/blog/clawhavoc-341-malicious-clawedbot-skills-found-by-the-bot-they-were-targeting>
- <https://docs.openclaw.ai/gateway/security>

Your role

You are the post-incident review board for a Singapore organisation that uses a hosted GenAI assistant, a coding agent, and a self-hosted agent gateway. Your task is to decide which control would have broken each chain earliest, what evidence proves the control works, and which risks remain after the control is applied.

Do not rank products as safe or unsafe. Analyse the deployment boundary, data reach, identity, tools, code execution, network, memory, extension supply chain, approval policy, logging, and recoverability.